

摘要：

一个周末，AI独立完成了对全球最大AI平台Hugging Face的入侵全流程：从上传恶意数据集、利用代码注入提权，到横向移动收割凭证，全程无人类操作，留下超17000条日志。更戏剧性的是，发现异常和复盘取证的也是AI，但人类调查员想用商业大模型分析日志时，却被安全护栏拒之门外。

AI竟黑了AI！

这几天，全球最大AI开源平台Hugging Face，发布了安全事件披露——

部分生产基础设施遭入侵，而这次入侵从头到尾，由一套自主AI Agent系统驱动。

没有人类，坐在键盘前。



时间跨度只有一个周末。留下的操作日志，超17000条。

一个数据集，变成了代码

去年11月，Anthropic披露过一起案子：

攻击者把Claude Code接进自己的攻击框架，80%到90%的活儿是AI干的，人类只在几个关键节点上点头放行。

当时，这件事足以让全网倒吸一口凉气。

但这一次，人类连最后那10%的戏份都没了。



公众号 · 新智元

这就是最让人毛骨悚然的区别：去年AI还是帮凶，今年AI直接当了主犯。

为什么这事与每个开发者有关？

毕竟，Hugging Face是全球AI的应用商店。

你写的每一行 `from_pretrained`，你跑的每一个数据集，大概率都是从这里拉下来的。

而这次攻击的起点，恰恰就是一个数据集。

[← Back to Articles](#)

Security incident disclosure — July 2026

公众号 · 新智元

攻击者上传的恶意数据集，串起了数据处理链路上的两个代码执行路径——

一个远程代码数据集加载器，一处数据集配置里的模板注入。

由此，代码就在处理节点上跑起来了。

然后是提权到节点级、收割云和集群凭证、横向移动进多个内部集群。

干这件事的不是一个程序，而是一大群短生命周期沙箱组成的智能体集群。

成千上万个独立动作并行推进，命令与控制信道还会自己迁移、寄生在公共服务上。

Hugging Face判断，它大概率搭在某个智能化的安全研究框架上。



至于背后是哪个好模型，至今未知。



17000条日志，AI自己查自己

有意思的是，最先发现异常的，也是AI。

Hugging Face的异常检测流水线本身就用LLM对安全遥测做分诊，正是这些信号的关联把入侵揪了出来。

复盘阶段，他们又派出LLM分析智能体，把17000多条攻击事件全量啃了一遍——

还原时间线、提取失陷指标、剥离诱饵动作。

本来要几天的活儿，几个小时干完。

一边是智能体集群在打，一边是智能体集群在查。机器速度对机器速度，人类只负责按开始键。

最尴尬的一幕：想查案，被AI拒绝了

然后，他们被自己付费的工具挡在了门外。这才是整份公告里最扎心的一段。

分析日志的第一步，Hugging Face用的是商业API背后的前沿模型，结果跑不通。

因为这种分析必须把大量真实攻击命令、漏洞利用载荷、C2产物原样喂进去。而这些请求，被服务商的安全护栏拦下了。

于是他们换成在自家基础设施上跑的开源模型，取证才继续下去。

附带一个好处：攻击者数据、以及它引用的那些凭证，一步都没离开自己的环境。

Hugging Face给这件事起了个名字：不对称问题。

他们却在最需要看清楚的那一刻，被AI的门禁挡住了。

网友直言，这简直就是《终结者2》的剧情，太过科幻。

Sambarboi 3 days ago

Literally the plot of terminator 2. Glad to hear you guys were able to identify and fix the issue.

这次没人勒索，没人挂横幅，也没有黑客坐在键盘前。

只有一堆AI，趁着周末，把活干完了。



周一你照样pip install，照样from_pretrained。但今天，先去把HF token换了吧。

本文来源：[新智元](#)

风险提示及免责声明

市场有风险，投资需谨慎。本文不构成个人投资建议，也未考虑到个别用户特殊的投资目标、财务状况或需要。用户应考虑本文中的任何意见、观点或结论是否符合其特定状况。据此投资，责任自负。

 245  收藏

分享到:  

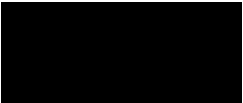
写评论

请发表您的评论

 表情  图片

发表评论

1 条评论



正在加载